

Industry references (CIS, NIST, FFIEC, Azure authority map)

Industry references (standards authority map)

Purpose: Authoritative external sources behind prescriptive choices in this engagement’s standards pack. Use for client GRC review, CAB packets, and auditor evidence. **Not legal advice** — client GRC validates applicability.

Internal standards using these references:

1. US financial sector governance

Framework	Reference	Used for
FFIEC Information Security Handbook	ithandbook.ffiec.gov	Secure configuration, access control, change management, vendor/cloud risk
FFIEC Cybersecurity Assessment Tool (CAT)	ffiec.gov/cyberassessmenttool.htm	Maturity mapping for platform controls
FFIEC Outsourcing Technology Services	FFIEC IT Examination Handbook — Outsourcing	Cloud (Azure) third-party dependency documentation
GLBA Safeguards Rule	FTC Safeguards Rule	Administrative/technical safeguards for customer information
SOX ITGC	COSO Internal Control Framework	Change management evidence (IaC, image versions, deploy approvals)
PCI DSS v4 (if CDE)	pcisecuritystandards.org	Req. 2 (secure config), 6 (secure dev), 10 (logging)

2. Cybersecurity frameworks

Framework	Reference	Maps to our controls
NIST Cybersecurity Framework 2.0	nist.gov/cyberframework	Identify, Protect, Detect, Respond, Recover
NIST SP 800-53 Rev. 5	csrc.nist.gov SP 800-53	CM-, SI-, AU-, IA-, AC-* families
NIST SP 800-190 (application container security)	csrc.nist.gov SP 800-190	Podman runtime, image build, registry isolation
NIST SP 800-207 (Zero Trust)	csrc.nist.gov SP 800-207	Per-VM UAMI, least privilege, no standing admin
CIS Critical Security Controls v8	cisecurity.org/controls	Inventory, secure config, continuous vuln management, audit logs
CIS Benchmarks program	cisecurity.org/cis-benchmarks	OS and cloud hardening methodology

3. OS baseline — RHEL 9

Topic	Reference	Our implementation
CIS Red Hat Enterprise Linux 9 Benchmark (Level 1)	CIS RHEL 9 Benchmark	Primary baseline — OpenSCAP in golden image
DISA STIG — RHEL 9	cyber.mil STIGs STIG Viewer	Optional only if GRC mandates — do not stack with CIS L1 without approval
OpenSCAP	open-scap.org	Scan/remediate/verify in AIB
ComplianceAsCode / scap-security-guide	github.com/ComplianceAsCode/content	CIS and STIG profiles for RHEL 9
RHEL 9 Security Hardening	Red Hat — Security hardening	SELinux, SSH, audit, crypto policy
RHEL 9 Managing systems with RHEL system roles	Red Hat — RHEL system roles	Ansible hardening patterns
SELinux for containers	Red Hat — Container SELinux	Podman volume contexts
dnf-automatic	Red Hat — dnf-automatic	Security-only patching
FIPS 140	Red Hat — FIPS mode	App-team validation before enable

4. Containers — Podman, supply chain, CI/CD

Topic	Reference	Our implementation
Podman documentation	docs.podman.io	Runtime standard (no Docker daemon)
Quadlet / systemd units	podman-systemd.unit(5)	<code>.container</code> , <code>.network</code> under <code>/etc/containers/systemd/</code>
Red Hat UBI 9	catalog.redhat.com — UBI	Base image recommendation
NIST SP 800-190	SP 800-190	Registry isolation, non-root where feasible, image provenance
SLSA (Supply-chain Levels for Software Artifacts)	slsa.dev	Build provenance target (Level 2+)
OpenSSF Best Practices	openssf.org	OSS dependency and CI hygiene
GitHub Actions — self-hosted runners	About self-hosted runners	Dedicated runner VM, lower trust zone
GitHub Actions — environments	Using environments for deployment	Required reviewers for UAT/prod
GitHub OIDC with Azure	OIDC in Azure	Federated credentials vs SP secrets
CNCF Software Supply Chain Best Practices	tag-security/supply-chain	Image signing, SBOM

5. Azure platform — identity, network, compute

Topic	Reference	Our implementation
Microsoft Cloud Security Benchmark (MCSB)	Azure security baseline	NSG, identity, logging alignment
CIS Microsoft Azure Foundations Benchmark	CIS Azure Benchmark	Subscription/resource hardening
Azure Landing Zone	Cloud Adoption Framework — Landing zone	Hub/spoke advisory (client implements)
Network Security Groups	NSG overview	Deny-all inbound default
Azure Bastion	Bastion overview	SSH path — no public IP
Private Link / Private Endpoint	Private Endpoint overview	ACR, Key Vault, Azure Files
User-assigned managed identity	Managed identities overview	One UAMI per VM
Entra ID — Linux SSH sign-in	Sign in to Linux with Entra ID	Retire shared admin
Privileged Identity Management	PIM overview	Developer + consultant JIT access
Key Vault best practices	Key Vault best practices	No secrets in images/git
Trusted Launch	Trusted Launch	Secure Boot + vTPM
Azure Shared Image Gallery	SIG overview	Golden image versioning
Azure Image Builder	AIB overview	Layer 1 pipeline
Azure Policy	Azure Policy documentation	SIG-only, no public IP samples

6. Azure Container Registry and monitoring

Topic	Reference	Our implementation
ACR best practices	Container registry best practices	Premium, PE, RBAC
ACR security baseline	ACR security	UAMI auth, admin disabled
ACR content trust / signing	Container image trust	Required before prod
Defender for Containers	Defender for Cloud — containers	Vulnerability scanning
Azure Monitor Agent	AMA overview	DCR + Log Analytics
Data Collection Rules	DCR overview	Syslog + perf counters
Azure Monitor logs for Linux	Log Analytics agent migration	AMA (not legacy MMA)

7. Backup, DR, and operations

Topic	Reference	Our implementation
Azure Backup	Azure Backup overview	Runtime data disk
Azure Site Recovery	ASR overview	Runtime VM + disk replication
Azure Files NFS	Azure Files NFS	Optional shared ingestion
ITIL change management	Axelos ITIL 4	CAB, standard vs emergency change

8. Ingress and API edge (advisory)

Topic	Reference	Our default
nginx reverse proxy	nginx — proxy module	Sidecar on runtime VM :8080
Azure API Management	APIM overview	Future option — change order
OWASP API Security Top 10	owasp.org/API-Security	Token validation, ingress hardening

9. Per-document quick index

Internal doc	Primary external authorities
	CIS RHEL 9 L1, Red Hat hardening, Podman/Quadlet, MCSB, SP 800-190
	FFIEC IS Handbook, NIST CSF, CIS Controls, SLSA, ITIL
	MCSB, CIS Azure, PIM, Entra SSH, NSG, SP 800-207
	ACR best practices, SP 800-190, SLSA, Defender for Containers
	FFIEC data flows, Azure outbound rules, Private Link
	CAF landing zone, Trusted Launch, CIS Azure
	PIM, least privilege, MCSB identity
	OWASP API, APIM, nginx
	ACR, GitHub Actions, SP 800-190
	SIG, AIB, CIS, MCSB, three-layer separation
	FFIEC, NIST 800-53, PCI, CIS, STIG
	ITIL change, NIST IR, Red Hat ops guides

10. Red Hat subscription and support

Topic	Reference
RHEL on Azure	Red Hat on Azure
RHSM	Red Hat Subscription Management
Red Hat Customer Portal	access.redhat.com

Maintenance

Review links **quarterly** or when CIS/NIST/Azure releases major updates. Report broken links to platform team.

Version	Date	Notes
1.0	2026-05-28	Initial authority map for standards pack